

CodeFriend Review Report

Source and scope

- **Repository:** <https://github.com/vectordotdev/vector>
- **Revision:** 410da89a0ed42c523143da89fffeb7f6402833e0
- **Scope digest:**
9ab817de155ee4d1a207d0d61adeb3d02c7fc3317c99c9be1f56e56482fac421
- **Run:**
469c73b02b07ba956be4e7221246a545bcdad20a4ea5fa010816cde3c4f9626b
- **Completion:** complete
- **Included paths:**
 - Cargo\.toml
 - LICENSE
 - README\.
 - lib\dnsmmsg\parser\Cargo\.
 - lib\dnsmmsg\parser\LICENSE
 - lib\dnsmmsg\parser\benches\benches\.
 - lib\dnsmmsg\parser\src\dns_message\.
 - lib\dnsmmsg\parser\src\dns_message_parser\.
 - lib\dnsmmsg\parser\src\ede\.
 - lib\dnsmmsg\parser\src\lib\.
- **Excluded paths:**
 - all_paths_outside_declared_scope
- **Run failures:** none

Publication approval

- **Decision:** approved
- **Decision digest:**
d230fb6d7deb23b1795346b7b9adac9bbc26b419e9219a718fb3a15ce3e48d21
- **Approved by:** operator\-fixture
- **Reason:** Exact semantic inputs approved for deterministic PDF rendering
- **Approved at:** 1700000000
- **Publication binding:**
91c9ab26cbd3c04781fd1f5c9f66eb8e3eff2ed994c7131bb58d73e0ac4770c1
- **Target:** approved\pdf-report
- **Renderer:** v1\printpdf-0\12\8
- **Claims:**
 - Approved exact PDF review semantics
- **Nonclaims:**
 - No HTML, Markdown, remote, or customer publication

Findings

Possible mutation of raw message buffer in DNS message parser to evade detection or cause inconsistent parsing

444d15b0eae2ba3720852d84136753351fb94e180d7313056d0ef9aff96d88c2

- **Anchor:** DnsMessageParser struct and

- **Severity rationale:** adversarial: Résumé café π with a long URL

[illegible]

****Remediation plan****

- **Acceptance criteria:**
- Resolve synthesized finding
444d15b0eae2ba3720852d84136753351fb94e180d7313056d0ef9aff96d88c2 without changing unrelated scope\.
- Retain traceability to evidence ids:
a993dc62a8392670ae6667bb1a4bf994b0a57343f958a3d9bd36f16a78b10573\.
- Add or update focused validation proving the bounded repair and negative case\.
- **Validation:**
- Run the smallest focused test covering the repaired path\.
- Run git diff \-check over the exact candidate\.
- Independent reviewer must verify finding
444d15b0eae2ba3720852d84136753351fb94e180d7313056d0ef9aff96d88c2 is resolved and no unrelated finding was bundled\.
- **Risk, non-goals and uncertainty:**
- Do not create issues, assign humans, publish PRs, or mutate source as part of planning\.
- Do not combine unrelated findings merely because they share severity\.
- Preserve scope limits: adversarial: Analysis is limited to the provided code and does not include all call sites of the DNS parser which may influence exploitability\.
- **Additional uncertainty:**
- adversarial: Analysis is limited to the provided code and does not include all call sites of the DNS parser which may influence exploitability\.

Test plan

- **Test:** Focused regression test: Possible mutation of raw message buffer in DNS message parser to evade detection or cause inconsistent parsing
- **Test ID:**
a472cd3de2805de44d9bae9e5df2da39355088a5ebe64ee264ccc74ddf0f0681
- **Finding ID:**
444d15b0eae2ba3720852d84136753351fb94e180d7313056d0ef9aff96d88c2
- **Severity:** high
- **Source finding IDs:**
- 65417167b20837b21e97cec196683f68b6ae88a7b8d7067f1306ef7c153933d2
- **Source evidence:**
- a993dc62a8392670ae6667bb1a4bf994b0a57343f958a3d9bd36f16a78b10573
- **Behavior under test:** Verify
`lib/dnsmmsg\parser/src/dns\\_message\\_parser.rs` keeps DNS RDATA name decoding isolated per message: repeated
`DnsMessageParser::get\\_rdata\\_decoder\\_with\\_raw\\_message` calls must not reuse or cumulatively extend `raw\\_message\\_for\\_rdata\\_parsing` with unrelated attacker-controlled raw RDATA from a prior call.
- **Proposed location:** lib/dnsmmsg\parser/src/dns_message_parser.rs
- **Fixture:** In `lib/dnsmmsg\parser/src/dns\\_message\\_parser.rs`'s existing `#[cfg(test)] mod tests`, add
`test\\_compressed\\_rdata\\_buffer\\_is\\_replaced\\_between\\_calls`.

Decode the existing MINFO message

\`5ZWBgAABAAEAAAAABm1pbmZvbwhleGFtcGxIMQNjb20AAAA4AAcAMAA4AAQAADGsADQRmcm
VkwBMDam9lwBMAACkQAAAAAAAAHAAKABgZ5zwJEK3VJQEAAABfSBqpS2bKf9CNBXg=` and
first RDATA `BGZyZWTAEWnqb2XAEw==`; on the same parser, then pass a
second MINFO `NULL` payload

`b"\x05alice\x07example\x03com\x00\x03bob\x07example\x03com\x00

". Assert the first result is `fred.example1.com`.

joel.example1.com`, the second is `alice.example.com`.

bob.example.com`, and the retained buffer length equals

`parser.raw\_message().len() + second\_rdata.len()` rather
than both RDATA payloads cumulatively.

- **Expected pre-fix failure:** Before the fix, the second same-parser
MINFO decode starts at the original message boundary but reads the first
appended RDATA, yielding `fred.example1.com joel.example1.com`
instead of the second payload's `alice.example.com`.

bob.example.com`; the retained buffer also includes both RDATA
payloads.

- **Expected post-fix assertion:** After the fix, the first MINFO result
equals `fred.example1.com joel.example1.com`, the second equals
`alice.example.com bob.example.com`, and
`raw\_message\_for\_rdata\_parsing().unwrap().len()` equals
`raw\_message().len() + second\_rdata.len()`; any prior-call
influence fails one of those exact assertions.

- **Validation lane:** PVF local focused validation plus git diff

\\-check

- **Resource profile:** local deterministic CPU/filesystem; no provider
credentials, network, source mutation, or paid infrastructure

- **Detection rationale:** Targets finding

444d15b0eae2ba3720852d84136753351fb94e180d7313056d0ef9aff96d88c2 by
exercising `lib/dnsmgsl-parser/src/dns\_message\_parser.rs` through
the exact state-reuse risk described in the accepted synthesis: same
parser, multiple decode calls, attacker-controlled raw RDATA, and an
assertion that prior-call bytes cannot affect the later decode.

- **Test non-goals:**

- Do not implement the production repair in the test-plan step.

- Do not mirror the implementation by asserting only function names or
snapshot text.

- Do not mutate repository source while generating the plan.

- **Test scope limits:**

- adversarial: Analysis is limited to the provided code and does not
include all call sites of the DNS parser which may influence
exploitability.

Output boundary

This is the canonical local PDF rendering of the approved review. It
does not claim HTML, Markdown, remote, or customer publication.